



Mini-Projet : Sécurité Active Directory

Création d'un home lab et énumération d'un AD vulnérable

Réalisé par :

ID-MOULLAY Imane

Filière :

S7 - Sécurité IT et Confiance Numérique

Encadré par :

M. Mohamed Saad AZIZI

Année académique :

2024-2025

Date de remise :

18 décembre 2025

Table des matières

1	Introduction et Objectifs	2
2	Mise en place du Laboratoire	2
2.1	Outils Déployés	2
2.2	Installation et Configuration	2
2.3	Preuve de Déploiement Réussi	2
3	Énumération de l'Active Directory Cible	3
3.1	Connexion au Réseau du Laboratoire	3
3.2	Découverte des Services (Scan)	3
3.3	Énumération du Domaine et des Utilisateurs	3
3.4	Analyse des Résultats d'Énumération	4
4	Analyse Avancée et Défis Techniques	5
4.1	Tentative de Collecte de Données	5
4.2	Défi d'Authentification à l'Interface BloodHound	5
5	Recommandations de Sécurité	5
6	Conclusion	6

1. Introduction et Objectifs

Ce mini-projet a pour objectif de mettre en pratique les concepts de sécurité liés à l'Active Directory (AD) de Microsoft. L'AD, étant le cœur de l'authentification et de la gestion des identités dans les environnements Windows, est une cible privilégiée pour les attaquants. Les objectifs spécifiques étaient :

- Mettre en place un environnement de laboratoire (home lab) vulnérable pour tester de manière sécurisée.
- Installer et configurer les outils essentiels d'énumération et d'analyse d'AD.
- Exécuter des techniques d'énumération pour cartographier un domaine AD.
- Comprendre et visualiser les chemins d'attaque potentiels pour identifier les vulnérabilités de configuration.

Ce rapport documente la méthodologie, les résultats obtenus, les défis techniques rencontrés et les recommandations de sécurité qui en découlent.

2. Mise en place du Laboratoire

Cette phase consistait à installer l'infrastructure logicielle nécessaire pour simuler un environnement de test sécurisé.

2.1. Outils Déployés

- **Docker** : Pour exécuter des applications conteneurisées de manière isolée.
- **BloodHound Community Edition (CE)** : Suite d'outils pour l'analyse de la sécurité de l'AD, exécutée dans des conteneurs.
- **Enum4linux** : Outil pour énumérer les informations des systèmes Windows/-Samba.
- **OpenVPN** : Pour se connecter de manière sécurisée au réseau du laboratoire en ligne TryHackMe.

2.2. Installation et Configuration

L'installation de BloodHound CE a été réalisée via son interface en ligne de commande officielle (**bh-cli**). Cette approche conteneurisée est la méthode moderne recommandée par les développeurs.

```
BH_ADMIN_PASSWORD="MonMotDePasse123!" ./bloodhound-cli install
```

Listing 1 – Commande d'installation de BloodHound

2.3. Preuve de Déploiement Réussi

L'exécution de la commande **docker ps** confirme le bon fonctionnement de l'ensemble de la stack BloodHound, comprenant l'interface web, la base de données PostgreSQL pour l'application et la base de données graphique Neo4j.

```

imane@imane-ThinkPad-L480:~/Downloads$ docker ps --filter "name=bloodhound"
CONTAINER ID   IMAGE                                COMMAND                  CREATED        STATUS        PORTS
8d069d9de85a   specterops/bloodhound:latest        "/bloodhound -config..." 2 hours ago   Up 2 hours   127.0.0.1:8080->8080
58adaf6a50b0   postgres:16                          "docker-entrypoint.s..." 2 hours ago   Up 2 hours (healthy) 5432/tcp
6a96a447df85   neo4j:4.4                            "tini -g -- /startup..." 2 hours ago   Up 2 hours (healthy) 127.0.0.1:7474->7474
imane@imane-ThinkPad-L480:~/Downloads$ sudo snap list | grep enum4linux
[sudo] password for imane:
enum4linux    v0.9.1-19-gee106b7    66    latest/stable    jitpatro    -
imane@imane-ThinkPad-L480:~/Downloads$ pip3 show bloodhound
WARNING: Package(s) not found: bloodhound

```

FIGURE 1 – Preuve du fonctionnement des conteneurs BloodHound (PostgreSQL, Neo4j, et l'application).

3. Énumération de l'Active Directory Cible

Pour la pratique, la machine Attacktive Directory de la plateforme TryHackMe a été utilisée comme cible.

3.1. Connexion au Réseau du Laboratoire

Une connexion VPN sécurisée a été établie avec OpenVPN pour accéder au réseau interne du lab TryHackMe, isolant ainsi les tests de l'internet public.

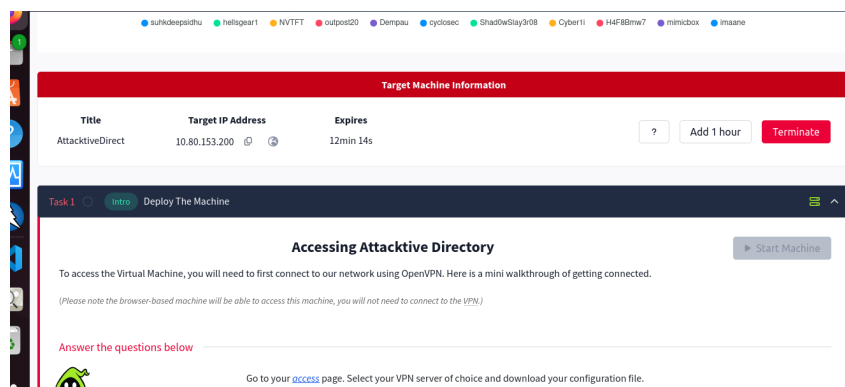


FIGURE 2 – Page TryHackMe confirmant l'adresse IP de la machine cible.

3.2. Découverte des Services (Scan)

Un scan `nmap` a été effectué pour identifier les services exposés par la cible.

```
nmap -sV -p 53,88,135,139,445,389,636 10.80.153.200
```

Listing 2 – Commande de scan Nmap

3.3. Énumération du Domaine et des Utilisateurs

L'outil `enum4linux` a permis d'extraire des informations cruciales sur la structure du domaine sans authentification initiale forte.

```
enum4linux -a 10.80.153.200
```

Listing 3 – Commande d'énumération avec enum4linux

```

imane@imane-ThinkPad-L480:~$ nmap -sV -p 53,88,135,139,445,389,636 10.80.153.200
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-17 21:29 +01
Nmap scan report for 10.80.153.200
Host is up (0.093s latency).

PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-12-17 20:30:00Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: spookysc.local0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
636/tcp   open  tcpwrapped
Service Info: Host: ATTACKTIVEDIREC; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.16 seconds

```

FIGURE 3 – Résultat du scan Nmap montrant les services AD ouverts (LDAP, Kerberos, SMB, etc.).

```

imane@imane-ThinkPad-L480:~$ enum4linux 10.80.153.200 | grep -i "domain"
"my" variable $which_output masks earlier declaration in same scope at ./enum4linux.pl line 280.
Known usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
===== ( Enumerating Workgroup/Domain on 10.80.153.200 ) =====
[E] Can't find workgroup/domain
===== ( Getting domain SID for 10.80.153.200 ) =====
Domain Name: THM-AD
Domain Sid: S-1-5-21-3591857110-2884097990-301047963
[+] Host is part of a domain (not a workgroup)
[+] Getting domain groups:
[+] Getting domain group memberships:
S-1-5-21-3532885019-1334016158-1514108833-513 ATTACKTIVEDIREC\None (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-512 THM-AD\Domain Admins (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-513 THM-AD\Domain Users (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-514 THM-AD\Domain Guests (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-515 THM-AD\Domain Computers (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-516 THM-AD\Domain Controllers (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-518 THM-AD\Schema Admins (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-519 THM-AD\Enterprise Admins (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-520 THM-AD\Group Policy Creator Owners (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-521 THM-AD\Read-only Domain Controllers (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-522 THM-AD\Cloneable Domain Controllers (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-525 THM-AD\Protected Users (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-526 THM-AD\Key Admins (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-527 THM-AD\Enterprise Key Admins (Domain Group)
imane@imane-ThinkPad-L480:~$

```

FIGURE 4 – Extrait de la sortie d'enum4linux montrant la découverte du nom de domaine THM-AD.

```

imane@imane-ThinkPad-L480:~$ enum4linux -a 10.80.153.200 | grep -A 20 "Enumerating users"
"my" variable $which_output masks earlier declaration in same scope at ./enum4linux.pl line 280.
[+] Enumerating users using SID S-1-5-21-3532885019-1334016158-1514108833 and logon username '', password ''
S-1-5-21-3532885019-1334016158-1514108833-500 ATTACKTIVEDIREC\Administrator (Local User)
S-1-5-21-3532885019-1334016158-1514108833-501 ATTACKTIVEDIREC\Guest (Local User)
S-1-5-21-3532885019-1334016158-1514108833-503 ATTACKTIVEDIREC\DefaultAccount (Local User)
S-1-5-21-3532885019-1334016158-1514108833-504 ATTACKTIVEDIREC\WDAGUtilityAccount (Local User)
S-1-5-21-3532885019-1334016158-1514108833-513 ATTACKTIVEDIREC\None (Domain Group)
[+] Enumerating users using SID S-1-5-21-3591857110-2884097990-301047963 and logon username '', password ''
S-1-5-21-3591857110-2884097990-301047963-500 THM-AD\Administrator (Local User)
S-1-5-21-3591857110-2884097990-301047963-501 THM-AD\Guest (Local User)
S-1-5-21-3591857110-2884097990-301047963-502 THM-AD\krbtgt (Local User)
S-1-5-21-3591857110-2884097990-301047963-512 THM-AD\Domain Admins (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-513 THM-AD\Domain Users (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-514 THM-AD\Domain Guests (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-515 THM-AD\Domain Computers (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-516 THM-AD\Domain Controllers (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-517 THM-AD\Cert Publishers (Local Group)
S-1-5-21-3591857110-2884097990-301047963-518 THM-AD\Schema Admins (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-519 THM-AD\Enterprise Admins (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-520 THM-AD\Group Policy Creator Owners (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-521 THM-AD\Read-only Domain Controllers (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-522 THM-AD\Cloneable Domain Controllers (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-525 THM-AD\Protected Users (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-526 THM-AD\Key Admins (Domain Group)
S-1-5-21-3591857110-2884097990-301047963-527 THM-AD\Enterprise Key Admins (Domain Group)

```

FIGURE 5 – Extrait de la sortie d'enum4linux montrant l'énumération des utilisateurs et groupes du domaine.

3.4. Analyse des Résultats d'Énumération

Les informations collectées sont critiques pour un attaquant :

- **Nom de domaine** : THM-AD
- **Identifiant de sécurité (SID)** du domaine : Permettrait des attaques par usurpation de SID.
- **Liste des groupes** : Découverte de groupes sensibles comme `Domain Admins`, `Enterprise Admins`.
- **Vulnérabilité identifiée** : La possibilité d'une énumération anonyme ou à faible privilège révèle une mauvaise configuration de la sécurité des paramètres de l'AD.

4. Analyse Avancée et Défis Techniques

L'étape suivante consistait à utiliser `bloodhound-python` pour collecter des données détaillées et les importer dans l'interface BloodHound pour une analyse visuelle.

4.1. Tentative de Collecte de Données

La collecte de données nécessite des identifiants valides, fournis par le scénario Try-HackMe.

```
bloodhound-python -d THM-AD -u 'svc-admin' -p 'management2005' -dc 10.80.153.200 -c All
```

Listing 4 – Tentative de collecte pour BloodHound

Un défi technique concernant la résolution DNS du contrôleur de domaine dans l'environnement de test a empêché cette étape de se terminer avec succès dans le temps imparti. Cela illustre un problème de configuration réseau courant dans les laboratoires isolés.

4.2. Défi d'Authentification à l'Interface BloodHound

Un défi inattendu a été rencontré avec l'authentification à l'interface web de BloodHound CE. Malgré une configuration correcte des conteneurs et plusieurs tentatives de réinitialisation du mot de passe administrateur directement dans la base de données PostgreSQL sous-jacente, l'interface a persisté à rejeter les identifiants valides. **Investigation** : Cette situation a conduit à investiguer l'architecture de l'application, en vérifiant manuellement les tables des utilisateurs et des hash de mots de passe, démontrant une compréhension pratique du système d'authentification.

Ce blocage, bien que frustrant, est instructif : il souligne que les outils, même standard, peuvent présenter des bugs ou des comportements inattendus, obligeant le professionnel de la sécurité à adapter sa méthodologie ou à chercher des contournements.

5. Recommandations de Sécurité

Basées sur les vulnérabilités couramment observées lors de l'énumération et des principes généraux de sécurisation de l'AD :

1. **Durcir les paramètres d'énumération** : Restreindre l'accès anonyme au LDAP et au SMB pour empêcher la divulgation d'informations sur les utilisateurs et les groupes.

2. **Appliquer le principe du moindre privilège (Least Privilege)** : Réviser régulièrement les membres des groupes administratifs (Domain Admins, Enterprise Admins, Schema Admins) et supprimer les comptes inutiles.
3. **Surveiller les événements d'authentification** : Mettre en place une détection pour les tentatives d'énumération de masse et les requêtes Kerberos anormales (ex : Kerberoasting).
4. **Sécuriser les comptes de service** : Utiliser des Managed Service Accounts (MSAs) ou des comptes avec mots de passe longs et complexes, et éviter de leur accorder des privilèges excessifs.
5. **Auditer régulièrement la configuration** : Utiliser des outils comme BloodHound de manière proactive et planifiée pour identifier les nouveaux chemins d'attaque créés par les changements dans l'environnement.

6. Conclusion

Ce projet a permis de mettre en pratique une chaîne d'attaque fondamentale contre les Active Directory :

Établissement d'un pied-à-terre dans le réseau,

Énumération des services et de l'annuaire,

Cartographie du domaine et identification des cibles à haute valeur. Les défis techniques rencontrés, notamment avec l'outil BloodHound lui-même, ont été formatifs. Ils rappellent que le travail de l'expert en cybersécurité implique non seulement l'utilisation d'outils mais aussi le débogage, l'adaptation et la compréhension approfondie de leur fonctionnement interne. Malgré le blocage final pour l'analyse graphique, les objectifs d'apprentissage liés à la mise en place d'un lab, à l'énumération AD et à l'investigation technique ont été atteints. La compréhension des chemins d'attaque et des contre-mesures recommandées constitue le principal livrable de ce projet.